

TAREA NDC05

Normativa vigente de ciberseguridad de ámbito nacional e internacional.

Autor: Carlos España Del Pozo - CETI

Contenido

Detalles de la tarea de esta unidad	3
Apartado 1: Marco Jurídico y Directiva NIS 2	3
Respuestas 1	3
Apartado 2: Transición a ISO/IEC 27001:2022	5
Respuestas 2	5
Apartado 3: Análisis de Continuidad y Resiliencia (Directiva CER y BIA)	6
Respuestas 3	6
Apartado 4: Esquema Nacional de Seguridad (ENS)	8
Respuestas 4	8

Detalles de la tarea de esta unidad

Caso práctico

Empresa: ACME S.A. (Proveedor de Servicios de Telecomunicaciones).

Contexto: ACME tiene 300.000 clientes particulares y empresariales. Es adjudicataria de los servicios de comunicaciones de las embajadas en España y proveedor de una gran entidad bancaria internacional.

Sede: Oficinas inteligentes inauguradas en 2020 con alta eficiencia energética y zonas de acceso público (parques).

Datos económicos para el análisis de impacto:

- *SLA (Acuerdo de Nivel de Servicio) Clientes Empresa: Garantía del 99%. Compensaciones a partir de los 30 minutos de caída.*
- *Coste por interrupción: A partir de la primera hora de caída completa del servicio, las compensaciones ascienden a 500.000 € por cada hora adicional.*
- *Impacto en imagen: Se estima una pérdida fija de 200.000 € por incidente (pérdida de clientes y nuevas altas) independientemente de la duración, si el incidente se hace público.*
- *Apetito de riesgo: La organización establece que bajo ningún concepto puede asumir pérdidas superiores a 1,5 millones de euros en un solo incidente.*

Como responsable de seguridad de ACME S.A., debes actualizar el plan de cumplimiento normativo para el año en curso, dado que han entrado en vigor nuevas directivas europeas y se han actualizado los estándares internacionales.

Apartado 1: Marco Jurídico y Directiva NIS 2

ACME S.A. opera en el sector de las infraestructuras digitales y telecomunicaciones, y además provee servicios a la Administración Pública.

1. Identificación normativa: Enumera las 4 leyes o directivas principales (nacionales o europeas) que aplican obligatoriamente a ACME S.A. en materia de seguridad física y lógica.
2. Clasificación NIS 2: Según la nueva Directiva (UE) 2022/2555 (NIS 2), ¿ACME S.A. se clasificaría como una Entidad Esencial o una Entidad Importante? Justifica tu respuesta basándote en los sectores afectados descritos en la adenda.
3. Responsabilidad directiva: El CEO de ACME te pregunta qué le podría pasar a él personalmente si ignora las medidas de ciberseguridad bajo la nueva directiva NIS 2. Explícale brevemente las consecuencias para la dirección.

Respuestas 1

Basándonos en la información de la unidad y los datos facilitados con la actual normativa, podemos indicar lo siguiente:

1. Las principales normas que aplican obligatoriamente a ACME S.A. en materia de ciberseguridad y seguridad física son:

1. Directiva (UE) 2022/2555 NIS 2

Regula la seguridad de redes y sistemas de información en sectores críticos como telecomunicaciones e infraestructuras digitales.

A. Directiva NIS 2 (sustituye a la Directiva NIS 1)

El material original explicaba la Directiva NIS de 2016. Esta ha sido derogada por la **Directiva (UE) 2022/2555**, conocida como **NIS 2**.

Principales Novedades:

1. **Ampliación de Sectores:** Ya no se distingue solo entre "Operadores de Servicios Esenciales" y "Proveedores de Servicios Digitales". Ahora se clasifican en:
 - o **Entidades Esenciales:** Energía, transporte, banca, salud, agua, administración pública, espacio.
 - o **Entidades Importantes:** Correos, gestión de residuos, química, alimentación, industria manufacturera, proveedores digitales.
 2. Reglamento General de Protección de Datos (RGPD)
Regula el tratamiento y protección de datos personales de los clientes.
 3. Directiva CER (sustituye a la Directiva de Infraestructuras Críticas 2008)
Se ocupa de la seguridad física y la resiliencia ante amenazas no cibernéticas en sectores críticos alineada con la Directiva NIS2

B. Directiva CER (sustituye a la Directiva de Infraestructuras Críticas 2008)

El material mencionaba la Directiva 2008/114/CE. Esta ha sido sustituida por la **Directiva (UE) 2022/2557 (Directiva CER)** sobre la resiliencia de las entidades críticas.

- Mientras que la NIS 2 se ocupa de la **ciberseguridad**, la Directiva CER se ocupa de la **seguridad física y la resiliencia** ante amenazas no cibernéticas (desastres naturales, terrorismo físico, sabotaje).
- Ambas directivas están alineadas para garantizar una protección integral (física + lógica).

4. Esquema Nacional de Seguridad (ENS)

Obligatorio para empresas que prestan servicios a la Administración Pública española, como en el caso de las embajadas.

2. En base a la información facilitada, ACME S.A. se clasificaría como **Entidad Esencial**.

Según la **Directiva (UE) 2022/2555 NIS 2**, se consideran **entidades esenciales** las organizaciones que operan en sectores críticos, entre ellos:

- Telecomunicaciones
- Infraestructuras digitales
- Servicios para administraciones públicas

Y ACME:

- Es proveedor de **servicios de telecomunicaciones**

- Tiene **300.000 clientes**
- Proporciona servicios a **embajadas y entidades financieras**

Por lo tanto, cumple plenamente los criterios de **infraestructura crítica**, lo que la clasifica como **Entidad Esencial**.

- Al CEO de la compañía, le indicamos que, la Directiva (UE) 2022/2555 NIS 2 introduce responsabilidad directa de la dirección si ignora las medidas de ciberseguridad, pudiendo recibir sanciones administrativas y económicas personales, además, las autoridades pueden inhabilitar temporalmente a directivos para ejercer cargos y la empresa puede recibir multas de hasta 10 millones de euros o el 2% de la facturación anual global.

Apartado 2: Transición a ISO/IEC 27001:2022

El cliente bancario de ACME exige que la certificación de seguridad se actualice a la versión ISO/IEC 27001:2022.

- Nueva estructura: Explica brevemente cómo ha cambiado la estructura de los controles del Anexo A (comparando la versión 2013 con la 2022). ¿Cuáles son los 4 nuevos "Temas" en los que se agrupan los controles?
- Selección de controles nuevos: De los 11 nuevos controles introducidos en la versión 2022, selecciona DOS que sean críticos para ACME S.A. y justifica su elección basándote en el caso práctico (ej. su actividad internacional, el uso de servicios en la nube, etc.).

Nota: Debes indicar el nombre del control y por qué aplica al caso.

Respuestas 2

En base a la información facilitada en la unidad podemos indicar lo siguiente:

- La norma ISO/IEC 27001:2022 introduce cambios importantes respecto a ISO/IEC **27001:2013**.

Característica	Versión 2013	Versión 2022
Número de controles	114	93
Organización	14 dominios	4 temas
Cambios	Controles separados	Controles fusionados y simplificados

El cambio más importante se encuentra en el Anexo A

Los 4 nuevos temas de controles son:

- Organizacionales: 37 controles (políticas, roles, inteligencia de amenazas...).
- Personas: 8 controles (trabajo remoto, concienciación, confidencialidad...).
- Físicos: 14 controles (seguridad de oficinas, mantenimiento, monitoreo...).
- Tecnológicos: 34 controles (autenticación, malware, redes, cifrado...).

2. Entre los 11 nuevos controles, los más relevantes para ACME serían:

1. Inteligencia de amenazas (Threat Intelligence)

ACME presta servicios a:

- Embajadas
- Una entidad bancaria internacional

Estos clientes pueden ser objetivo de ciberataques avanzados o espionaje estatal.

2. Seguridad en servicios en la nube (Cloud Security)

ACME probablemente utiliza Infraestructura cloud

Este control permite garantizar seguridad en servicios cloud y proteger datos de clientes y administraciones

Apartado 3: Análisis de Continuidad y Resiliencia (Directiva CER y BIA)

1. Directiva CER: Dado que ACME tiene una sede física crítica y provee servicios esenciales, la nueva Directiva CER (resiliencia de entidades críticas) le aplica. A diferencia de la NIS 2, ¿de qué tipo de amenazas debe protegerse ACME para cumplir con la CER? Pon un ejemplo basado en la descripción de su sede (jardines, acceso público, etc.).

2. Cálculo de parámetros BIA: Realiza el análisis de impacto basándote en los datos económicos proporcionados:

- Calcula el coste total del incidente si el servicio cae durante 1 hora, 2 horas y 3 horas.
- Determina el MTPD (Tiempo Máximo Tolerable de Interrupción) exacto antes de superar el límite de pérdidas de 1,5 millones de euros.
- Propón un RTO (Objetivo de Tiempo de Recuperación) lógico para este escenario.

Respuestas 3

1. **ACME S.A.** para cumplir con la **Directiva (UE) 2022/2557 CER** debe protegerse frente a:

- Sabotaje físico
- Terrorismo
- Vandalismo
- Desastres naturales
- Intrusiones físicas

Ejemplo: Las oficinas tienen zonas verdes de acceso público.

Un atacante podría acceder al recinto y sabotear cableado o infraestructura de telecomunicaciones por ello se requiere de control de accesos, videovigilancia y seguridad perimetral física.

2. Análisis BIA

En base a los datos facilitados el análisis es el siguiente:

- **Compensación por caída de servicio:** 500.000 € por cada hora adicional después de la primera
- **Impacto reputacional:** 200.000 € por incidente
- **Límite de riesgo de la empresa:** 1.500.000 €
- Coste del incidente según duración de la caída

Duración de la caída	Compensación SLA	Impacto reputacional	Coste total
1 hora	0 €	200.000 €	200.000 €
2 horas	500.000 €	200.000 €	700.000 €
3 horas	1.000.000 €	200.000 €	1.200.000 €
4 horas	1.500.000 €	200.000 €	1.700.000 €

- Análisis del MTPD

Concepto	Resultado
Límite de pérdidas aceptado	1.500.000 €
Coste estimado a las 3 horas	1.200.000 €
Coste estimado a las 4 horas	1.700.000 €
MTPD estimado	Entre 3 y 4 horas (≈ 3,6 horas)

- Objetivo de recuperación (RTO)

Parámetro	Valor	Justificación
RTO	2 horas	Permite recuperar el servicio antes de superar el límite de pérdidas.

Apartado 4: Esquema Nacional de Seguridad (ENS)

ACME presta servicios a las embajadas, lo que implica tratar información clasificada o sensible de la Administración Pública.

1. Categorización del sistema: Determina la categoría del sistema (Básica, Media o Alta) según el ENS. Para ello, valora las dimensiones de Confidencialidad y Disponibilidad para el servicio de las embajadas. Justifica por qué asignas ese nivel a cada dimensión (piensa en el impacto de que se filtren comunicaciones diplomáticas o que estas se corten).

2. Declaración de aplicabilidad: Si el sistema resulta ser de categoría MEDIA o ALTA, ¿es suficiente con aplicar los controles básicos? ¿Qué tipo de auditoría externa debería pasar ACME cada dos años según el ENS para mantener la conformidad?

Respuestas 4

1. Según el Esquema Nacional de Seguridad (ENS), se valoran tres dimensiones. (C, I, A)

Confidencialidad -> ALTA

ACME gestiona comunicaciones diplomáticas de embajadas.

Si se filtran:

- espionaje internacional
- crisis diplomática
- impacto en seguridad nacional.

Disponibilidad -> ALTA

Una interrupción del servicio podría:

- cortar comunicaciones diplomáticas
- impedir coordinación entre embajadas
- afectar relaciones internacionales.

La categorización del sistema sería de nivel: **ALTO**

2. Declaración de aplicabilidad y auditoría

Si el sistema es MEDIA o ALTA:

- NO es suficiente aplicar controles básicos.
- Deben aplicarse controles medios o altos del ENS.

Además, ACME deberá realizar:

Auditoría externa de conformidad del ENS cada 2 años.